Monthly Intelligence Dispatch

December 2021

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Group-IB Digital Forensics and Threat Intelligence teams examined the latest available samples of Hive and analyzed the affiliate program from the inside for the first time, tracing it back to the moment of its creation.
- Microsoft seized dozens of malicious domains used by the Chinese-backed APT15 group for targeting various organizations worldwide.
- Quebec shut down nearly 4,000 of its websites in response to the discovery of the Log4Shell flaw in the Apache Log4j Java-based logging library.
- Proofpoint researchers uncovered a campaign exclusively targeting French entities and organizations with the banking malware TinyNuke.
- Cofense researchers discovered a new phishing campaign that took place in the last few weeks: threat actors used QR codes to target users of German e-banking services.
- The Conti ransomware gang started a campaign called **ARMattack** on November 16, 2021. In the course of this campaign, hackers successfully attacked various organizations from different countries.
- The overall size of initial access market hits $7.2 mln: in H2 2020-H12021, the market of corporate initial access continued to flourish and grew by almost 16% from $6,189,388 to $7,165,387.
- Group-IB identified at least 24 groups attacking financial sector companies. The most prolific among them were REvil, Conti, and Avaddon.
- The US court sentenced Russian citizen Oleg Koshkin to 4 years in prison for taking part in the development of the Kelihos Botnet.

Group-IB Digital Forensics and Threat Intelligence teams examined the latest available samples of Hive and analyzed the affiliate program from the inside for the first time, tracing it back to the moment of its creation.

Hive

In July 2021, the REvil ransomware operators demanded a record-breaking ransom of $70 million from a meat giant JBS in exchange for a decryption key. The record did not last long though, since in less than half a year the ransomware empire tripled this amount, bringing it to $240 million. The demand was sent to the Europe's largest consumer electronics retailer Media Markt, which fell prey to a ransomware attack in November. It turned out that the perpetrator behind the incident was Hive, an organization that took a back seat for quite some time in the past. Just as REvil, the Hive gang used the Ransomware-as-a-Service (RaaS) model and frequently pressured their victims threatening to publish the stolen data on their DLS (data leak sites where threat actors publish the companies' data in case the ransom demand is refused).

Hive affiliates have been busy as bees: the actual number of their victims is in the hundreds despite the fact that the affiliate program has been active for less than half a year. Group-IB Threat Intelligence analysts determined that as of October 16, 2021, at least 355 companies fell victim to the threat actor.

Log4Shell	Microsoft researchers reported that nation-state actors from China, Iran, North Korea, and Turkey are now abusing the Log4Shell (CVE-2021-44228) in the Log4J library as a part of their campaigns. Among the groups that exploit this vulnerability are China-backed Hafnium and Iran-backed Phosphorus. The former group uses this flaw to attack virtualization infrastructure while the latter focuses on deploying ransomware. This activity ranges from experimentation during development, integration of the vulnerability to in-the-wild payload deployment, and exploitation against targets to achieve the actor's objectives. For example, MSTIC has observed PHOSPHORUS, an Iranian threat actor that has been deploying ransomware, acquiring and making modifications of the Log4j exploit. We assume that PHOSPHORUS has operationalized these modifications. In addition, HAFNIUM, a group operating from China, has been observed using the vulnerability to extend their typical targeting by attacking virtualization infrastructure. In these attacks, HAFNIUM-associated systems were observed using a DNS service, which is typically associated with testing activity aimed at system fingerprinting.
APT 15	Microsoft announced to have obtained a court warrant that allowed it to seize 42 domains used by a China-linked APT 15 (aka Nickel, Ke3chang, Mirage, Vixen Panda, Royal APT and Playful Dragon) in recent operations that targeted organizations in the US and 28 other countries. APT15 has been active since at least 2010, it conducted cyber espionage campaigns against targets worldwide in several industries, including defense, high tech, energy, government, aerospace, and manufacturing. The attackers demonstrated an increasing level of sophistication across the years, they used custom-malware and various exploits in their attacks. The Microsoft Digital Crimes Unit (DCU) has disrupted the activities of a China-based hacking group called Nickel. In documents that were unsealed today, a federal court in Virginia has granted our request to seize websites Nickel was using to attack organizations in the United States and 28 other countries around the world, enabling us to cut off Nickel's access to its victims and prevent the websites from being used to execute attacks." – reads the post published by Microsoft.

Major events: espionage, sabotage, leaks

Cyberwarfare

Group-IB presents the fourth volume of its Hi-Tech Crime Trends 2021/2022 report **"Cyberwarfare: state-sponsored operations in cyberspace"**. During the reporting period, researchers discovered 11 new APT groups specializing in cyber espionage. Two of them — Dark Halo and HAFNIUM — carried out the most large-scale operations, competing with each other for the highest number of infected companies. The largest number of active APT groups was detected in the Asia-Pacific region, just like in the previous review period. One of the trends observed in the reporting period was APT groups using rootkits and vulnerabilities to compromise BIOS/UEFI and subsequently gain control of a system. The development of 5G technologies triggered the intensification of espionage campaigns, presumably aimed at competing for new markets in Southeast Asia, Europe, and the United States. The number of attacks on IT companies is growing year after year. In most cases, IT companies serve as a springboard for supply-chain attacks aimed at further compromising customers' data.

Initial Access Market

The overall size of the initial access market hits **$7.2 mln:** in H2 2020-H12021, the market of corporate initial access continued to flourish and grew by almost **16%** from **$6,189,388** to **$7,165,387**. Here are some more figures proving this explosive growth:

The number of offers to sell access to companies almost tripled over the review period: from **362** to **1,099**.

The number of initial access brokers skyrocketed from **86** currently operating players to **262**, with **229** newcomers joining the roster.

The number of industries exploited by initial access brokers surged from **20** to **35**, which indicates that cybercriminals are becoming aware of the variety of potential victims. Most companies affected belonged to manufacturing, education, and financial services.

The number of countries where cybercriminals broke into corporate networks increased from **42** to **68**. US-based companies were the most popular among threat actors that sell access to compromised networks, followed by France and the UK.

Five brokers make **35%** of all the profit from access sale in the underground market.

Major events: threats to banking customers

REvil, Conti, and Avaddon.	Group-IB presents the third volume of its Hi-Tech Crime Trends 2021/2022 report "Big money: threats to financial sector". Financial sector organizations face a diverse threat landscape, as they are often the preferred targets of financially motivated cybercriminals. In H2 2020 - H1 2021, the cyber threat that stood out as the most damaging to financial sector organizations was ransomware. In the review period the number of financial organizations whose data was released on DLS increased to 127 compared to 50 a year earlier. Group-IB identified at least 24 groups attacking companies in the financial sector. The most prolific among them were **REvil**, **Conti**, and **Avaddon**.
Access Brokers	The market for access to corporate networks has grown significantly. Compared to the previous period, the number of initial access brokers (IABs) has increased from 18 to 47 , while the number of known sale incidents went up from 31 to 95. Lull on the carding market. The review period saw a drastic decrease in the number of bank cards put up for sale. One of the key reasons for this decline was the closure of notorious card shop Joker's Stash, which used to account for 40% of the global carding market. In addition to Joker's Stash, more than 10 smaller card shops shut down in 2021. That said, the share of bank cards put up for sale by other card shops remained the same. This trend has been observed in all the regions.

TinyNuke	TinyNuke is back. The malware has recently been used in attacks aimed at French users who work in manufacturing, technology, construction, and business services.The attackers used invoice-themed lures targeting entities in manufacturing, industry, technology, finance, and other sectors. The banking malware reemerged after a significant slump in activity in 2019; these days, threat actors use it to steal credentials and other private information and deliver additional payloads.The TinyNuke malware was first spotted in 2017, but its usage peaked in 2018. “After only observing a handful of TinyNuke campaigns in 2019 and 2020, Proofpoint observed TinyNuke reappear in January 2021 in one campaign distributing around 2,000 emails. Subsequent campaigns appeared in low volumes in May, June, and September. In November, Proofpoint identified multiple TinyNuke campaigns distributing around 2,500 messages and impacting hundreds of customers.” reads the analysis published by Proofpoint. “In the most recent campaigns, the threat actor uses invoice-themed lures purporting to be logistics, transportation, or business services entities.” The malicious messages used in these campaigns contain download links pointing to a ZIP compressed executable responsible for installing TinyNuke.
Sparkasse, Volksbanken Raiffeisenbanken	Cofense researchers discovered a new phishing campaign that took place in the last few weeks: threat actors used QR codes to target users of German e-banking services. The messages used in the campaign were recently discovered by a cybersecurity firm Cofense. Threat actors used QR codes to deceive clients of two Geman financial institutions, Sparkasse and Volksbanken Raiffeisenbanken, and steal digital banking information.The phishing messages were carefully crafted; the content was well-structured and featured bank logos. Threat actors used different social engineering tricks to deceive the recipients, such as asking them to consent to data policy changes implemented by the bank or requesting them to review new security procedures. Upon clicking on the button included in the message, the recipient is redirected to a phishing landing page passing through Google’s feed proxy service ‘FeedBurner.’ Threat actors behind this campaign have been registering their own custom domains for redirection and using them as final phishing sites. New domains have recently been registered with the Russian registrar REG.RU. To avoid suspicion, the domain names follow a standard URL structure depending on the targeted financial organization.

Phishing and scam

Group-IB released the concluding part of our 5-volume Hi-Tech Crime Trends 2021/2022 report — **"Scams and Phishing: The epidemic of online fraud."** In this paper, Group-IB's CERT-GIB and Digital Risk Protection experts analyze major scam campaigns, as well as tools and infrastructure used by threat actors. The COVID-19 pandemic was the main reason for the explosive growth of online scams. According to Group-IB's data, fraud accounted for 74.5% of all online crimes in the first half of 2021. Scam (a type of fraud in which victims voluntarily make payments or disclose their data) accounted for more than half (57%) of all cybercrimes, while phishing (theft of bank card data) made up just 17.5%.

Here are some other highlights and trends from our latest report:

Group-IB specialists helped block more than 14,000 phishing resources hosted on some 12,000 unique domains. About 20% of phishing websites were hosted on compromised legitimate resources.

Classiscam became one of the largest, longest, and most technically advanced hybrid scam campaigns in the world. By the end of 2021, 70 active affiliate programs used this scheme, targeting more than 80 international brands from 36 countries.

In the reporting period, experts observed an increase in phishing campaigns targeting online services (16%) and social media (8%).

The popularity of the scam-as-a-service model has led to scams scaling up on a global level and to a lower entry threshold for newbie scammers.

Conti

Conti ransomware gang started a campaign called **ARMattack** on November 16, 2021. In the course of this campaign the hackers successfully attacked various organizations from different countries. Starting from November 17, 2021, the attackers gained access using the workstation CYPREXX1238. The initial vector of the attack is still unknown. In total, 4 devices were compromised. The list of compromised devices is shown in Appendix 1.According to our information, this workstation belongs to *Cyprexx*. After this workstation had been compromised, the attackers began internal reconnaissance. At this stage, they dumped password hashes and found other computers in the local network in order to infect them. The list of compromised password hashes is available in Appendix 2. The attackers also exfiltrated files from a local system using the Cobalt Strike framework. The list of exfiltrated files is presented in Appendix 3. The threat actors used the Cobalt Strike framework. We assume that the next step will be the deployment of CONTI ransomware and recommend starting the incident response procedure immediately. Timely incident prevention allows companies to mitigate the risks of encryption and further extortion. Conti is a private Ransomware-as-a-Service (RaaS) initially detected in November 2019 (test version) / Februaly 2020 (in-the-wild). This malicious software is notable for its advanced capabilities such as fast encryption, anti-analysis, and direct execution. It contains command-line options to scan for local files as well as remote files on SMB shares. Conti also uses the Windows Restart Manager to free up files that are opened by various applications. The ransomware uses AES-256 encryption and requires the victim to email a threat actor for the decryption key. Also, malefactors use a website for stolen data.

RaaS

Group-IB presents the second volume of its Hi-Tech Crime Trends 2021/2022 report "Corporansom: threat number one". In the first 11 months of 2021, more than 60% of all the incidents investigated by Group-IB concerned ransomware. This number is expected to grow, with the number of public affiliate programs growing by 23% in H2 2020 – H1 2021 compared to the corresponding period a year earlier.

Over the review period, RaaS gangs increased the conversion by posting compromised data online on their data leak websites (DLS). It has become very popular, with the number of victims whose data has been published on DLSs having grown by 935% in H2 2020 – H1 2021.

The report represents the first attempt at retrospective analysis of how the ransomware cyber empire evolved and sheds light on how businesses worldwide lose millions of dollars to cybercriminals. In this report, we look into how and why the ransomware industry has developed, provide in-depth analysis of certain affiliate programs from within, and share statistics on the countries and industries that are attacked most often. Let's take a look at the highlights of the report "Corporansom: threat number one":

According to data leak sites, in 2021, the most active ransomware groups were **Conti**, **Lockbit,** and **Avaddon**.

Almost half of the companies whose data was published on DLS in 2021 originate from the US, followed by Canada and France.

According to the DLS data, the main industries targeted in 2021 were manufacturing, real estate, and transportation. In 2020, the situation was very similar, suggesting that attackers mainly target the same types of companies from which, as they believe, they can profit the most.

Arrests and sentences

Oleg Koshkin

Russian national Oleg Koshkin, 41, has been sentenced to 48 months in prison for one count of conspiracy to commit computer fraud and abuse and one count of computer fraud and abuse. Koshkin was convicted in January for charges related to the operation of a malware crypting service used by the Kelihos botnet to obfuscate malware and evade detection.“A Russian national was sentenced today to 48 months in prison for operating a “crypting” service used to conceal the Kelihos malware from antivirus software, which enabled hackers to systematically infect approximately hundreds of thousands of victim computers around the world with malicious software, including ransomware.” reads the press release published by DoJ.“According to court documents, Oleg Koshkin, 41, was convicted by a federal jury on June 15 of one count of conspiracy to commit computer fraud and abuse and one count of computer fraud and abuse.” Koshkin operated the webservices “Crypt4U.com,” “fud.bz” and others that allowed their customers to render their malicious payloads undetectable by most of the antivirus engines. He has been in custody since 2019, when he was arrested in California. According to court documents, Koshkin supported his co-defendant, Pavel Tsurkan, who is the author of the Kelihos botnet, in the development of a system that would allow to crypt the Kelihos payloads multiple times each day. Koshkin provided Levashov with a custom crypting service that was used to distribute Kelihos through multiple criminal affiliates. Koshkin was arrested in California in September 2019, while Tsurkan was arrested in April 2017. The Kelihos botnet was used to send out a large volume of spam messages, conduct denial of service attacks, harvest account credentials, and distribute malware. In 2017, when FBI dismantled the Kelihos botnet, the malicious infrastructure was composed of at least 50,000 compromised devices around the world.

Forecasts and warnings

- According to data leak sites, in 2021, the most active ransomware groups were **Conti, Lockbit,** and **Avaddon**. We assume that the next step will be the deployment of CONTI ransomware and recommend starting the incident response procedure immediately. Timely incident prevention allows companies to mitigate the risks of encryption and extortion.
- Taking into account that Hive targets organizations from various economic sectors from all around the world and their attacks are manually controlled by the affiliates, it is crucial to closely monitor the changes in TTPs of these ransomware operators. Group-IB Digital Forensics and Threat Intelligence teams examined the latest available samples of Hive and analyzed the affiliate program from the inside for the first time, tracing it back to the moment of its creation. Check it out!
- Concerns over nation-state attackers grow every year. Group-IB's previous Hi-Tech Crime Trends reports have detailed how long-term espionage campaigns run by intelligence agencies occurred alongside episodes of open interstate military confrontation, which in some cases resulted in infrastructure being physically destroyed.
- Recently, state-backed attackers became less isolated from the rest of the cybercriminal world. More and more often, they use publicly available tools and resort to underground services. They do not shy away from buying initial access from other attackers or exchange malicious tools with them. Group-IB's hypothesis that the boundaries between nation-state and financially-motivated attackers are beginning to fade is confirmed by the fact that more state-sponsored hackers are trying their luck in new fields to increase their profits.

If you wish to receive more detailed information about a specific incident, threat, or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+65 3159 3798
+7 495 984 33 64
intelligence@group-ib.com